

Cybersecurity Interview Questions & Answers

Part- I

Beginner Level (Q1–Q40)

Q1. What is cybersecurity?

Cybersecurity is the practice of protecting systems, networks, and data from digital attacks.

Q2. What is a firewall?

A firewall is a security system that monitors and controls network traffic to prevent

unauthorized access.

Q3. What is malware?

Malware refers to malicious software like viruses, worms, spyware, and ransomware

designed to harm or exploit systems.

Q4. What is phishing?

Phishing is a cyber attack where users are tricked into revealing personal information

through fake emails or websites.

Q5. What is a virus vs a worm?

A virus attaches to files and needs user action to spread; a worm spreads on its own through

networks.

Q6. What is the CIA triad?

Confidentiality, Integrity, and Availability — core principles of information security.

Q7. What is encryption?

Encryption converts data into unreadable form to protect it from unauthorized access.

Q8. What is decryption?

Decryption is the process of converting encrypted data back into its original form.

Q9. What is a VPN?

A Virtual Private Network secures your internet connection and hides your IP address.

Q10. What is authentication?

The process of verifying the identity of a user or system.

Q11. What is authorization?

Determining what resources a user is allowed to access after authentication.

Q12. What is 2FA?

Two-Factor Authentication is a security method that requires two forms of verification.

Q13. What is a brute-force attack?

An attack that tries many combinations of passwords until the correct one is found.

Q14. What is a DDoS attack?

Distributed Denial of Service — an attack that overwhelms a service with traffic.

Q15. What is spyware?

Malware that secretly gathers user information without consent.

Q16. What is ransomware?

A type of malware that locks your files and demands payment to unlock them.

Q17. What is antivirus software?

A program designed to detect and remove malware.

Q18. What is patching?

The process of updating software to fix vulnerabilities.

Q19. What is a honeypot?

A decoy system used to attract and analyze attackers.

Q20. What is social engineering?

Manipulating people to reveal confidential information.

Q21. What is an IP address?

A unique identifier for a device on a network

Q22. What is a port number?

A number used to identify specific processes or services on a system.

Q23. What is the difference between HTTP and HTTPS?

HTTPS is secure and uses SSL/TLS encryption, while HTTP does not.

Q24. What is SQL Injection?

An attack where malicious SQL is inserted into queries to manipulate databases.

Q25. What is XSS?

Cross-Site Scripting — a vulnerability that allows attackers to inject scripts into web pages.

Q26. What is a botnet?

A network of infected computers controlled remotely by attackers.

Q27. What is a vulnerability?

A weakness in a system that can be exploited by attackers.

Q28. What is risk in cybersecurity?

The potential for loss or damage when a threat exploits a vulnerability.

Q29. What is mitigation?

Steps taken to reduce or eliminate security risks.

Q30. What is a backup?

A copy of data stored separately to recover in case of data loss.

Q31. What is a hash function?

It converts data into a fixed-length value for integrity checks.

Q32. What is salting in hashing?

Adding random data to passwords before hashing to prevent dictionary attacks.

Q33. What is DNS?

Domain Name System — it translates domain names into IP addresses.

Q34. What is MAC address?

A hardware identifier for network interfaces.

Q35. What is penetration testing?

Simulated cyberattack to test security of a system.

Q36. What is a white-hat hacker?

An ethical hacker who finds and fixes vulnerabilities.

Q37. What is a black-hat hacker?

A malicious hacker who exploits systems for illegal gain.

Q38. What is a zero-day vulnerability?

A flaw unknown to the vendor with no patch available.

Q39. What is an IDS?

Intrusion Detection System — monitors network traffic for threats.

Q40. What is an IPS?

Intrusion Prevention System — blocks threats detected by an IDS.

Intermediate Level (Q41–Q80)

Q41. What is SIEM?

Security Information and Event Management — a tool that collects and analyzes security logs.

Q42. What is SOC?

Security Operations Center — a team responsible for monitoring and responding to cyber threats.

Q43. What is threat intelligence?

Information about potential cyber threats used to defend against them.

Q44. What is incident response?

A structured approach to handle and manage the aftermath of a security breach.

Q45. What is lateral movement?

When an attacker moves within a network after gaining initial access.

Q46. What is port scanning?

Technique to identify open ports and services on a host.

Q47. What is vulnerability assessment?

Process of identifying and classifying security weaknesses.

Q48. What is Nmap?

A network scanning tool used to discover hosts and services.

Q49. What is Metasploit?

A penetration testing framework used to find and exploit vulnerabilities.

Q50. What is Wireshark?

A tool used to capture and analyze network traffic

Q51. What is OS fingerprinting?

Determining the OS of a system remotely using network behavior.

Q52. What is ARP spoofing?

Sending fake ARP messages to link an attacker's MAC address with an IP.

Q53. What is DNS spoofing?

Providing false DNS results to redirect users to malicious sites.

Q54. What is cross-site request forgery (CSRF)?

An attack where the user is tricked into performing unwanted actions.

Q55. What is log analysis?

Reviewing logs to detect anomalies and security incidents.

Q56. What is endpoint protection?

Security solutions deployed on end-user devices like laptops or phones.

Q57. What is least privilege?

Giving users the minimum access rights they need to do their jobs.

Q58. What is role-based access control (RBAC)?

Access control based on a user's role in the organization.

Q59. What is MFA?

Multi-Factor Authentication — uses more than two methods for authentication.

Q60. What is steganography?

Hiding information inside files, such as images or audio.

Q61. What is keylogger?

A tool that records keystrokes to steal passwords or data.

Q62. What is ethical hacking?

Testing systems for vulnerabilities in a legal and authorized way.

Q63. What is sniffing?

Capturing data packets to analyze traffic and extract information.

Q64. What is spoofing?

Imitating another device or user to gain unauthorized access.

Q65. What is session hijacking?

Stealing session tokens to impersonate a user.

Q66. What is the difference between IDS and IPS?

IDS detects threats, IPS blocks them in real-time.

Q67. What is asymmetric encryption?

Uses two keys — public for encryption and private for decryption.

Q68. What is symmetric encryption?

Uses one shared key for both encryption and decryption.

Q69. What is SSL/TLS?

Protocols that secure data transmission over the internet.

Q70. What is digital signature?

Used to verify authenticity and integrity of a message or document.

Q71. What is PKI?

Public Key Infrastructure — a system for managing digital certificates.

Q72. What is an attack surface?

The total number of possible ways an attacker can enter a system.

Q73. What is jailbreaking/rooting?

Removing OS restrictions to gain more control, which also increases risk.

Q74. What is security auditing?

A formal process to review and examine security controls.

Q75. What is a vulnerability scanner?

A tool that scans systems for known vulnerabilities.

Q76. What is a digital certificate?

An electronic document used to prove ownership of a public key.

Q77. What is a kill chain?

A model that describes the stages of a cyberattack.

Q78. What is blue teaming?

Defensive security team focusing on protecting systems.

Q79. What is red teaming?

Offensive security team that simulates attacks.

Q80. What is purple teaming?

Collaborative approach between red and blue teams to improve security.

● **Advanced Level (Q81–Q100)**

Q81. What is threat hunting?

Proactively searching for threats that evade existing security tools.

Q82. What is an APT?

Advanced Persistent Threat — a stealthy and prolonged cyberattack.

Q83. What is malware analysis?

Examining malware to understand how it works and how to stop it.

Q84. What is log correlation?

Combining logs from multiple sources to identify patterns.

Q85. What is a sandbox in cybersecurity?

A safe environment to run and observe suspicious code.

Q86. What is binary exploitation?

Attacking a system by exploiting vulnerabilities in binary code.

Q87. What is reverse engineering?

Analyzing software to discover its design and vulnerabilities.

Q88. What is fuzzing?

A testing technique that feeds random data to find bugs.

Q89. What is cyber threat intelligence (CTI)?

Collecting and analyzing threat data to make informed decisions.

Q90. What is a TTP?

Tactics, Techniques, and Procedures — the behavior patterns of attackers.

Q91. What is lateral movement in an attack?

When an attacker moves inside the network to find sensitive data.

Q92. What is EDR?

Endpoint Detection and Response — tools for monitoring and responding to threats on endpoints.

Q93. What is MITRE ATT&CK?

A knowledge base of adversary tactics and techniques based on real-world observations.

Q94. What is chain of custody in digital forensics?

The documentation of evidence handling to ensure its integrity.

Q95. What is data exfiltration?

Unauthorized transfer of data from a system.

Q96. What is key exchange?

The process of sharing cryptographic keys securely.

Q97. What is a zero-trust architecture?

Security model that assumes no user or system is trusted by default.

Q98. What is network segmentation?

Dividing a network into parts to improve security.

Q99. What is log retention policy?

Defines how long logs should be stored for auditing and compliance.

Q100. What is risk assessment?

Evaluating risks to prioritize security efforts.

Part- II

● Advanced Level (Q101–Q200)

Q101. What is the difference between vulnerability, threat, and risk?

Vulnerability: Weakness

Threat: Potential danger

Risk: Likelihood of threat exploiting a vulnerability

Q102. What is compliance in cybersecurity?

Following laws and standards like GDPR, HIPAA, ISO 2700

Q103. What is Security Information Management (SIM)?

SIM is the collection of data from security devices, network devices, systems, and applications to be correlated and analyzed for security purposes.

Q104. What is Security Event Management (SEM)?

SEM is the real-time monitoring, correlation of events, notifications, and console views for security events.

Q105. What is a reverse proxy?

A reverse proxy is a type of proxy server that retrieves resources on behalf of a client from one or more servers. These resources are then returned to the client, appearing as if they originated from the reverse proxy server itself.²

Q106. What is a forward proxy?

A forward proxy is a server that sits between a client and a destination server and forwards client requests to the destination server.

Q107. What is a Web Application Firewall (WAF)?

A WAF is a firewall that monitors, filters, and blocks HTTP traffic to and from a web service.

Q108. What is a Data Loss Prevention (DLP) solution?

A DLP solution is a system designed to detect and prevent sensitive data from leaving the organization's control.

Q109. What is cloud security?

Cloud security refers to the set of policies, controls, procedures and technologies that work together to protect cloud-based systems, data, and infrastructure.³

Q110. What is containerization in cybersecurity?

Containerization in cybersecurity refers to the use of containers (like Docker) to isolate applications and their dependencies, enhancing security by limiting the impact of a breach.

Q111. What is an exploit?

An exploit is a piece of software, data, or sequence of commands that takes advantage of a bug or vulnerability to cause unintended or unanticipated behavior⁴ to occur on computer software, hardware, or something electronic (usually computerised).⁵

Q112. What is a payload?

The payload is the part of the malware or exploit that performs the malicious action, such as stealing data, encrypting files, or granting remote access.

Q113. What is a back door?

A back door is a hidden method of bypassing normal authentication or encryption in a computer system, often used to gain remote access to a system.

Q114. What is buffer overflow?

A buffer overflow is an anomaly where a program, while writing data to a buffer, overruns the buffer's boundary and overwrites adjacent memory locations.

Q115. What is data integrity?

Data integrity refers to the accuracy, consistency, and trustworthiness of data over its entire lifecycle.

Q116. What is data availability?

Data availability ensures that authorized users can access information when and where they need it.

Q117. What is data confidentiality?

Data confidentiality ensures that sensitive information is accessed only by authorized individuals or systems.

Q118. What is a security policy?

A security policy is a document that outlines the rules and procedures for protecting an organization's information assets.

Q119. What is a security baseline?

A security baseline is a minimum set of security configurations and practices that an organization must adhere to.

120. What is a SIEM correlation rule?

A SIEM correlation rule is a set of conditions used by a SIEM system to identify suspicious patterns or events from aggregated logs.

121. What is threat modeling?

Threat modeling is a process of identifying and assessing potential threats to a system or application.

122. What is a security awareness program?

A security awareness program is designed to educate employees about cybersecurity risks and best practices.

123. What is secure coding?

Secure coding is the practice of writing software code in a way that minimizes vulnerabilities and protects against attacks.

124. What is input validation?

Input validation is the process of checking user input to ensure it meets specific criteria and does not contain malicious data.

125. What is output encoding?

Output encoding is the process of converting special characters into a different format to prevent them from being interpreted as code.

126. What is a security control?

A security control is a safeguard or countermeasure to avoid, detect, counteract, or minimize security risks to physical property, information, computer systems, or other assets.

127. What is a security audit?

A security audit is a systematic evaluation of the security of an organization's information system by measuring how well it conforms to a set of established criteria.

128. What is a Trusted Platform Module (TPM)?

A TPM is a secure cryptoprocessor that stores cryptographic keys to secure hardware.

129. What is a Hardware Security Module (HSM)?

An HSM is a physical computing device that safeguards and manages digital keys for strong authentication and provides cryptoprocessing.

130. What is Single Sign-On (SSO)?

SSO is an authentication scheme that allows a user to log in with a single ID and password to several related, yet independent, software¹² systems.

131. What is federation in identity management?

Federation is a system that allows users to access resources across different domains with a single identity.

132. What is security information management (SIM)?

SIM is the collection of data from security devices, network devices, systems, and applications to be correlated and analyzed for security purposes.

133. What is security event management (SEM)?

SEM is the real-time monitoring, correlation of events, notifications, and console views for security events.

134. What is serverless security?

Serverless security involves securing applications built on serverless architectures, addressing vulnerabilities unique to this environment like misconfigured permissions and insecure APIs.

135. What is memory forensics?

Memory forensics is the analysis of a computer's volatile memory (RAM) to investigate digital attacks and identify malicious activity.

136. What is network forensics?

Network forensics is a sub-branch of digital forensics relating to the monitoring and analysis of computer network¹³ traffic for the purpose of information gathering, legal evidence, or intrusion detection.¹⁴

137. What is endpoint forensics?

Endpoint forensics is the process of collecting and analyzing data from endpoints (e.g., laptops, desktops, mobile devices) to investigate security incidents.

138. What is digital evidence?

Digital evidence is any probative information stored or transmitted in digital form that a party to a court case¹⁵ may use at trial.

139. What is non-repudiation?

Non-repudiation is the assurance that someone cannot deny the validity of something.

140. What is a SIEM use case?

A SIEM use case defines a specific security scenario or threat that a SIEM system is configured to detect and alert on.

141. What is cyber kill chain methodology?

The cyber kill chain methodology is a framework developed by Lockheed Martin that describes the stages of a cyberattack, from reconnaissance to actions on objectives.

142. What is the principle of defense in depth?

Defense in depth is a cybersecurity strategy that uses multiple layers of security controls to protect information and systems.

143. What is the difference between a threat actor and a threat group?

A threat actor is an individual or entity responsible for a threat, while a threat group is a collective of threat actors working together.

144. What are Indicators of Compromise (IOCs)?

IOCs are pieces of forensic data, such as data found in system logs or files, that identify potentially malicious activity on a system or network.

145. What is a Threat Intelligence Platform (TIP)?

A TIP is a software solution that aggregates, processes, and disseminates threat intelligence data to security systems and analysts.

146. What is Security Orchestration, Automation, and Response (SOAR)?

SOAR is a stack of software programs that help organizations manage and respond to security threats and incidents.

147. What is User and Entity Behavior Analytics (UEBA)?

UEBA is a category of security solutions that use analytics to detect anomalous user and entity behavior that could indicate a security threat.

148. What is deception technology?

Deception technology involves deploying decoys and traps (like honeypots) to detect, engage, and learn from attackers.

149. What is Software-Defined Networking (SDN) security?

SDN security refers to the security implications and opportunities presented by software-defined networking, which allows for centralized control and programmability of network infrastructure.

150. What is a supply chain attack?

A supply chain attack is a cyberattack that targets less secure elements in the supply chain to gain access to the main target.

151. What is quantum cryptography?

Quantum cryptography is a field of cryptography that uses principles of quantum mechanics to ensure secure communication.

152. What is post-quantum cryptography?

Post-quantum cryptography is the development of cryptographic systems that are secure against quantum computer attacks.

153. What is homomorphic encryption?

Homomorphic encryption is a form of encryption that allows computations to be performed on encrypted data without decrypting it first.

154. What is blockchain in cybersecurity?

Blockchain in cybersecurity refers to the use of blockchain technology for enhancing security through decentralization, immutability, and transparency, such as in identity management or secure data sharing.

155. What is a Secure Development Lifecycle (SDL)?

An SDL is a security assurance process that focuses on security throughout the entire software development lifecycle.

156. What is a Security Operations Center (SOC) playbook?

A SOC playbook is a documented set of procedures and guidelines for the SOC team to follow when responding to specific security incidents.

157. What is Open-Source Intelligence (OSINT)?

OSINT is intelligence gathered from publicly available sources.

158. What is dark web monitoring?

Dark web monitoring is the process of actively searching the dark web for mentions of an organization's sensitive data, credentials, or other critical information.

159. What is cyber resilience?

Cyber resilience is an organization's ability to continuously deliver its intended outcome despite adverse cyber events.

160. What is an insider threat?

An insider threat is a security risk that originates from within the organization, often from employees, contractors, or business partners.

161. What is data masking?

Data masking is the process of obscuring specific data with altered data to protect sensitive information while maintaining its usability for testing or development.

162. What is tokenization?

Tokenization is the process of replacing sensitive data with a unique identifier (token) that retains all the essential information without compromising its security.

163. What is cryptojacking?

Cryptojacking is the unauthorized use of someone else's computer to mine cryptocurrency.

164. What is formjacking?

Formjacking is a type of cyberattack where attackers inject malicious JavaScript code into legitimate websites to steal payment card details and other sensitive information submitted by users.

165. What is fileless malware?

Fileless malware is a type of malicious software that operates in a computer's memory, making it difficult to detect by traditional antivirus software.

166. What is a Living Off The Land (LotL) attack?

A LotL attack involves using legitimate tools and processes already present on a compromised system to carry out malicious activities, making it harder to detect.

167. What is risk appetite?

Risk appetite is the amount and type of risk that an organization is willing to take in pursuit of its objectives.

168. What is risk tolerance?

Risk tolerance is the acceptable deviation from the risk appetite.

169. What is a Business Continuity Plan (BCP)?

A BCP is a plan to ensure that business operations continue even after a disaster or serious disruption.

170. What is a Disaster Recovery Plan (DRP)?

A DRP is a documented process or set of procedures to recover and protect a business IT infrastructure in the event of a disaster.¹⁸

171. What is Recovery Point Objective (RPO)?

RPO is the maximum acceptable amount of data loss measured in time.

172. What is Recovery Time Objective (RTO)?

RTO is the maximum acceptable downtime after a disaster.

173. What is ISO 27001?

ISO 27001 is an international standard for information security management systems (ISMS).

174. What is GDPR?

GDPR (General Data Protection Regulation) is a European Union law concerning data protection and privacy.

175. What is HIPAA?

HIPAA (Health Insurance Portability and Accountability Act) is a US law that protects sensitive patient health information.¹⁹

176. What is PCI DSS?

PCI DSS (Payment Card Industry Data Security Standard) is a set of security standards for organizations that handle branded credit cards.

177. What is the NIST Cybersecurity Framework?

The NIST Cybersecurity Framework is a set of guidelines and best practices to help organizations manage and reduce cybersecurity risk.

178. What is threat intelligence sharing?

Threat intelligence sharing is the process of exchanging information about cyber threats, vulnerabilities, and attack techniques between organizations.

179. What is behavior analytics in cybersecurity?

Behavior analytics in cybersecurity involves analyzing user and system behavior to detect anomalies and identify potential threats that might go unnoticed by traditional signature-based detection methods.

180. What is data provenance?

Data provenance refers to the origin and history of data, including where it came from, how it was created, and how it has been modified over time.

181. What is Explainable AI (XAI) in cybersecurity?

XAI in cybersecurity focuses on making the decisions of AI systems used for security (e.g., threat detection) more understandable and interpretable to human analysts.

182. What is Attack Surface Management (ASM)?

ASM is the continuous discovery, inventory, classification, and security monitoring of an organization's digital assets and potential attack vectors.

183. What is a security posture?

Security posture refers to the overall cybersecurity readiness and defensive capabilities of an organization at a given time.

184. What is a security architecture review?

A security architecture review is a formal assessment of an organization's security design and implementation to identify weaknesses and ensure alignment with security principles.

185. What is a security gateway?

A security gateway is a device or software that acts as an entry/exit point for network traffic, enforcing security policies and often integrating various security functions.

186. What is secure boot?

Secure boot is a security standard developed by PC companies to help make sure that a device boots using only software that is trusted by the original equipment manufacturer (OEM).

187. What is Endpoint Detection and Response (EDR) vs. Extended Detection and Response (XDR)?

EDR focuses on endpoints, while XDR expands to collect and correlate data across multiple security layers (endpoints, network, cloud, email, etc.) for broader threat detection and response.

188. What is container security?

Container security refers to the practices and tools used to protect

containerized applications and their underlying infrastructure throughout their lifecycle.

189. What is a security rating?

A security rating is a data-driven assessment of an organization's cybersecurity performance, often generated by third-party services.

190. What is a security scorecard?

A security scorecard is a tool that provides an overview of an organization's security posture, often using a grading system.

191. What is cyber insurance?

Cyber insurance is a type of insurance policy designed to protect businesses from the financial²⁰ impact of cyberattacks and data breaches.

192. What is a security budget?

A security budget is the financial allocation for cybersecurity initiatives, tools, personnel, and training within an organization.

193. What is a security roadmap?

A security roadmap is a strategic plan that outlines an organization's cybersecurity goals, initiatives, and timelines for implementation.

194. What is a security champion?

A security champion is an individual within a team or department who advocates for and helps implement security best practices.

195. What is secure software supply chain?

A secure software supply chain focuses on ensuring the integrity and security of all components, processes, and tools involved in software development and deployment.

196. What is a vulnerability management program?

A vulnerability management program is a continuous process of identifying, assessing, prioritizing, and remediating vulnerabilities in an organization's systems and applications.

197. What is an Incident Response Plan (IRP)?

An IRP is a detailed set of instructions to help an organization prepare for, detect, respond to, and recover from cyberattacks.

198. What is a cyber exercise?

A cyber exercise is a simulated cyberattack or incident designed to test an organization's preparedness and response capabilities.

199. What is a tabletop exercise?

A tabletop exercise is a discussion-based exercise where participants talk through their roles and responsibilities during a simulated cyber incident.

200. What is a full-scale exercise?

A full-scale exercise is a highly realistic simulation of a cyberattack, involving actual systems and personnel.